Secure Microsoft 365 Copilot — Oversharing & SharePoint Permissions Remediation

Implementation Solution Guide

Version 1.0.0 · 2026-07-09

Contents

Executive Summary — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 5

What this is . . . 5

The outcome . . . 5

The boundary . . . 5

Effort . . . 5

What is delivered . . . 6

1. Solution Overview — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 6

What it is . . . 6

How the technology works . . . 6

The standard deployment model — Assess → Configure → Pilot → Validate → Expand . . . 7

Scope . . . 7

What is out of scope . . . 7

Authentication & connections used . . . 8

2. Requirements — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 8

2.1 SharePoint Administrator (and read access for discovery) . . . 8

2.2 PowerShell modules — Microsoft Graph, PnP, SharePoint Online Management Shell . . . 8

2.3 SharePoint Advanced Management (SAM) — verify licensing . . . 9

2.4 A defined in-scope estate and pilot ring . . . 9

2.5 Site owners identified and available . . . 9

2.6 Sensitivity-label & DLP baseline (alignment, referenced) . . . 10

2.7 Change window and rollback plan . . . 10

2.8 Auditing enabled (for verification) . . . 10

Global Requirements — Copilot (category-level) 11

G1. Microsoft 365 tenant with supported workloads . . . 11

G2. Microsoft 365 Copilot licensing . . . 11

G3. Microsoft Entra ID identity and MFA . . . 11

G4. Data readiness — permissions & oversharing controls . . . 11

G5. Information protection baseline (sensitivity labels) . . . 12

G6. Administrative roles . . . 12

G7. Network and client readiness . . . 12

G8. Governance & responsible-use policy . . . 12

3. Implementation Guide — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 12

Objects you will create (naming reference) . . . 13
Step 0 — Confirm scope, licensing, roles, and connections (Assess) . . . 13
Step 1 — Discover the oversharing (Assess) . . . 14
Step 2 — Agree the remediation with site owners (Configure) . . . 14
Step 3 — Pilot: reduce access on the ring (Configure → Pilot) . . . 14
Step 4 — Align sensitivity labels & DLP (Configure) . . . 15
Step 5 — Validate the pilot, including from the Copilot side (Validate) . . . 16
Step 6 — Expand, remove interim controls, and record the evidence (Expand) . . . 16
5. Testing & Validation — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 17
Test 1 — Scope & connections (Step 0) . . . 17
Test 2 — Oversharing discovery produced (Step 1) . . . 17
Test 3 — Reduction list & owner decisions (Step 2) . . . 17
Test 4 — Remediation preview is safe (Step 3) . . . 17
Test 5 — Pilot access reduced (Step 3) . . . 18
Test 6 — Copilot honors the corrected permissions (Step 5) — decisive . . . 18
Test 7 — No legitimate collaboration broke (Step 5) . . . 18
Test 8 — Before/after evidence & recurring review (Step 6) . . . 18
Evidence to retain . . . 19
6. Troubleshooting — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 19
Discovery returns no sites / partial results . . . 19
Permission read is unavailable for a site . . . 19
Data Access Governance / RAC / RCD blades are missing . . . 19
Removed the grant, but Copilot still surfaces the content . . . 20
Restricted SharePoint Search broke legitimate search/Copilot . . . 20
Remediation broke legitimate collaboration . . . 20
`-WhatIf` shows a change you didn't approve . . . 20
SPO Management Shell RSS cmdlets not recognized . . . 21
Validation shows oversharing unchanged after remediation . . . 21
Auditing / verification data missing . . . 21
7. Best Practices — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 21
Keep it clean . . . 21
Where to go next (adjacent catalog areas) . . . 22
8. Deliverables Summary — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation 23
Documentation (8 guides) . . . 23

PowerShell scripts (5) 23
How it is delivered 24
Boundaries recap 24
Appendix A — PowerShell Scripts 26

Executive Summary — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

What this is

A self-guided, field-tested playbook that closes the **Copilot oversharing gap** at its source — the **SharePoint Online and OneDrive permissions** that decide what Copilot can surface. Copilot creates no new access; it inherits every grant a user already has. On the day Copilot is enabled, every over-shared site, every "Everyone Except External Users" (EEEU) grant, every anonymous link, and every stale permission becomes one prompt away. This solution finds that exposure, fixes it, and proves Copilot only returns what it should.

The outcome

• **A measured inventory of oversharing** — broad-access sites, EEEU / organization-wide grants, anonymous ("Anyone") links, and stale permissions across the in-scope SharePoint/OneDrive estate.

• **Remediated access** — broad grants removed or scoped, high-risk sites fenced with **SharePoint Advanced Management (SAM) **controls (**Restricted Access Control**,** Restricted Content Discovery**) and, as an interim stopgap, tenant** Restricted SharePoint Search**.

• **Sensitivity-label + DLP alignment** so the corrected boundaries are reinforced by information protection, not just sharing settings.

• **Proof it worked** — a re-measure showing the oversharing signal reduced, plus a Copilot-side verification that a test user can no longer surface content they should not reach.

The boundary

This solution remediates **SharePoint/OneDrive access and discovery scope** so Copilot honors the real boundary. It is the SharePoint-permissions counterpart to the Copilot data-governance solution (labels + DLP for Copilot), and it references — rather than duplicates — the Purview information- protection build. **SharePoint Advanced Management, Restricted Content Discovery, and Restricted SharePoint Search are licensing-/tenant-dependent and evolving — availability is flagged "verify," never assumed. Data-owner decisions** — who *should* have access to a given site, what is "too broad," and which content must be fenced — remain with the **site owners and the business**; this package supplies the discovery, the technical remediation method, and the evidence, not the access determinations.

Effort

A competent M365/SharePoint administrator can run the **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model in roughly **2–5 working days** for a pilot ring, then repeat the pattern per wave. Discovery, validation, and reporting are automated with read-only PowerShell (Microsoft Graph / PnP PowerShell); every change is previewed with `-WhatIf` and piloted before broad rollout.

What is delivered

Eight guides (this summary, overview, requirements, implementation, testing, troubleshooting, best practices, deliverables) and **five safe-by-default PowerShell scripts** (read-only discovery, validation, reporting; `-WhatIf`-gated remediation; access-review workbook) — all white-label, no secrets in code, delivered as a Complete Solution Package (PDF + Word + scripts).

1. Solution Overview — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

What it is

A repeatable method to **discover, remediate, and verify** the SharePoint Online / OneDrive access that governs what Microsoft 365 Copilot can surface. Copilot reasons over Microsoft Graph content — files, sites, pages, chats — and returns anything the prompting user technically has permission to open. If a site is shared with "Everyone Except External Users," if an anonymous link is live, or if a user carries stale membership from a former role, Copilot can pull that content into a response. This solution closes that gap by fixing the underlying permissions, not by turning Copilot off.

How the technology works

- **Copilot honors existing permissions.** It adds no access of its own. The exposure is entirely a

function of the current SharePoint/OneDrive sharing and permission state — so remediation is a SharePoint access-governance exercise, surfaced by Copilot.

- **The oversharing signals** that matter for Copilot: sites/items granted to **EEEU** or an org-wide

group; **"Anyone" (anonymous) links**; broad company-wide sharing links; large-membership sites; and **stale permissions** (guests, former team members, orphaned groups).

- **SharePoint Advanced Management (SAM)** provides the tenant-scale levers: **Data Access Governance

(DAG) reports **(oversharing / sharing-links / EEEU / sensitivity-labelled content),** Restricted Access Control (RAC) **to lock a site to a named group,** Restricted Content Discovery (RCD) **to exclude specific sites' content from Copilot and org-wide search, and** site access reviews** that push cleanup back to owners. *(SAM is a licensed add-on — verify current availability in your tenant.)*

- **Restricted SharePoint Search (RSS)** is a tenant-wide **interim** control: an allow-list of up to

100 sites that Copilot/enterprise search may use, blocking the rest — a stopgap while you clean up, not the end state. *(Verify current availability.)*

- **Information protection alignment.** Sensitivity labels with **encryption / usage rights** are honored

by Copilot at the item level; DLP for Copilot keeps labelled content out of AI responses. This solution *aligns* with that layer (built in the Copilot data-governance solution) so access is defended in depth.

- **Automation** is PowerShell: **Microsoft Graph** and **PnP PowerShell** for read-only discovery and

validation; the **SharePoint Online Management Shell** (`Set-SPOTenantRestrictedSearchMode`, etc.) for RSS; the SharePoint admin center and SAM blades for RAC/RCD/DAG.

The standard deployment model — Assess → Configure → Pilot → Validate → Expand

1. **Assess** — confirm scope, licensing, roles, connections; run read-only discovery to inventory the

oversharing across the in-scope estate and rank the worst offenders.

1. **Configure** — with site owners, agree the remediation list; stage the access changes, SAM RAC/RCD,

and interim RSS as **previews /** `-WhatIf` first.

1. **Pilot** — apply remediation to a **pilot ring** of sites; nothing tenant-wide is enforced yet.

2. **Validate** — re-measure the oversharing signal on pilot sites; verify from the **Copilot side** that

a test user can no longer surface content they should not reach; check no legitimate collaboration broke.

1. **Expand** — roll remediation to the remaining waves under change control, remove interim RSS/RCD once

the underlying access is fixed, record the before/after report, and stand up a recurring review.

Scope

• Discovery of SharePoint/OneDrive oversharing signals across the in-scope estate.

• Permission remediation: removing/scoping EEEU and org-wide grants, revoking anonymous/company links,

cleaning stale access, and driving owner-led site access reviews.

• SAM controls where licensed: RAC, RCD, and DAG-report-driven prioritization; interim RSS at tenant

scope.

• Sensitivity-label + DLP **alignment** so corrected access is reinforced by information protection.

• Copilot-side verification that responses honor the corrected permissions.

What is out of scope

• **Data-owner access determinations** — who should have access, and what counts as "too broad" — are the

business's decision; this guide gives the method and evidence.

• **Building the sensitivity-label taxonomy and DLP-for-Copilot policies** — delivered in the Copilot

data-governance solution and the Purview information-protection solutions; referenced here, not rebuilt.

• **Copilot licensing/enablement, network/client readiness, and identity hardening** — covered by the

Copilot global requirements and the Entra solutions.

• **Regulatory, records, and legal determinations** — remain with compliance/legal.

Authentication & connections used

• **Microsoft Graph PowerShell** (`Connect-MgGraph`, read scopes e.g. `Sites.Read.All`, `Directory.Read.All`) — read-only discovery/validation.

• **PnP PowerShell** (`Connect-PnPOnline`) — read-only site/permission enumeration and reporting.

• **SharePoint Online Management Shell** (`Connect-SPOService`) — RSS and tenant sharing controls.

• **SharePoint admin center / SAM blades** (`https://<tenant>-admin.sharepoint.com`) — DAG reports, RAC, RCD, site access reviews.

• **Roles:** SharePoint Administrator for remediation; Global Reader / read scopes for discovery; Security/Compliance roles for the label/DLP alignment (see the global requirements file). Reserve Global Administrator for tenant-wide changes only.

> *The category-level prerequisites (tenant, Copilot licensing, Entra identity/MFA, admin roles, network/client readiness, governance policy) live in* `global-requirements-copilot.md` *— confirm those first; this solution's specific prerequisites are in doc 2.*

2. Requirements — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

The category-level prerequisites (Microsoft 365 tenant and workloads, Copilot licensing, Entra ID identity/MFA, administrative roles, network/client readiness, and governance/responsible-use policy) are covered once in `global-requirements-copilot.md` — confirm those first and do not repeat them here. Below are the prerequisites **specific to this oversharing-remediation solution**. Each: **Description / Why required / How to verify / How to implement if missing.**

2.1 SharePoint Administrator (and read access for discovery)

• **Description:** A SharePoint Administrator role for remediation, plus a reader identity (Global Reader or the read Graph scopes below) for discovery.

• **Why required:** Removing broad grants, applying RAC/RCD, and running RSS require SharePoint Administrator; discovery only needs read.

• **How to verify:** Entra portal → **Roles and administrators** → confirm **SharePoint Administrator** on the operator; confirm a reader identity for discovery.

• **How to implement if missing:** Assign SharePoint Administrator (least privilege for this task); reserve Global Administrator for tenant-wide changes only.

2.2 PowerShell modules — Microsoft Graph, PnP, SharePoint Online Management Shell

• **Description:** `Microsoft.Graph` (for discovery/validation), `PnP.PowerShell` (site/permission reporting), and `Microsoft.Online.SharePoint.PowerShell` (RSS / tenant sharing controls) installed on the operator workstation.

• **Why required:** The bundled scripts and the RSS control depend on these modules.

• **How to verify:** `Get-Module Microsoft.Graph,PnP.PowerShell,Microsoft.Online.SharePoint.PowerShell -ListAvailable`. The discovery script also reports which modules are present.

• **How to implement if missing:** `Install-Module Microsoft.Graph -Scope CurrentUser`; `Install-Module PnP.PowerShell -Scope CurrentUser`; `Install-Module Microsoft.Online.SharePoint.PowerShell -Scope CurrentUser`. PowerShell 7+ recommended. *(PnP PowerShell app-registration/consent requirements have changed over time — verify the current sign-in method for your tenant.)*

2.3 SharePoint Advanced Management (SAM) — verify licensing

• **Description:** SharePoint Advanced Management, which unlocks Data Access Governance reports, Restricted Access Control, Restricted Content Discovery, and site access reviews.

• **Why required:** These are the tenant-scale levers for prioritizing and fencing oversharing; without SAM you fall back to manual sharing cleanup and interim RSS.

• **How to verify:** SharePoint admin center → look for **Reports** → **Data access governance** and the **Restricted Content Discovery** / **Restricted access control** controls. *(SAM is a paid add-on and its feature surface evolves — verify current availability and licensing in your tenant.)*

• **How to implement if missing:** Acquire the SAM add-on, or proceed with manual remediation + interim RSS and note SAM controls as pending. The scripts degrade gracefully when SAM is absent.

2.4 A defined in-scope estate and pilot ring

• **Description:** The list of SharePoint sites / OneDrive accounts in scope, and a **pilot ring** of sites to remediate first.

• **Why required:** Remediation is piloted before broad rollout; you must know which sites are in scope and which are the pilot targets.

• **How to verify:** A documented site list (from the SharePoint admin center **Active sites** export or the discovery script) and an agreed pilot subset.

• **How to implement if missing:** Export **Active sites** from the SharePoint admin center; agree a pilot ring (e.g. the sites that back the Copilot pilot cohort) with the site owners.

2.5 Site owners identified and available

- **Description:** Named **owners** for the in-scope sites who can make (or approve) access decisions.
- **Why required:** *Who should have access* is a data-owner determination, not an admin one; site access

reviews and grant removals need owner input to avoid breaking legitimate collaboration.

- **How to verify:** Each in-scope site has a current owner in **Site permissions**; owners are reachable for the pilot window.
- **How to implement if missing:** Assign/confirm site owners before remediation; where a site is orphaned, escalate to the business to name one.

2.6 Sensitivity-label & DLP baseline (alignment, referenced)

- **Description:** A published sensitivity-label taxonomy and, ideally, DLP-for-Copilot policies (built in the Copilot data-governance solution / Purview information-protection solutions).
- **Why required:** This solution *aligns* corrected access with information protection so boundaries are defended in depth; labels with encryption/usage rights are honored by Copilot at item level.
- **How to verify:** Purview portal → **Information Protection** shows published labels; DLP shows any Copilot-scoped policies.
- **How to implement if missing:** Not a hard blocker for permission remediation — proceed, and build the

label/DLP layer via the Copilot data-governance solution. Note label alignment as pending.

2.7 Change window and rollback plan

- **Description:** An agreed change window for enforcement steps and a documented rollback (restore prior

sharing, disable RSS, remove RCD).

- **Why required:** Removing broad access and enabling RSS/RCD can affect legitimate collaboration; a window and rollback keep it safe and reversible.
- **How to verify:** A recorded change window and a rollback note per remediation action; the discovery export is retained as the before-state.
- **How to implement if missing:** Schedule the window; keep the `Oversharing Discovery – Estate – Assess` export as the restore reference before making any change.

2.8 Auditing enabled (for verification)

- **Description:** Microsoft Purview / unified audit logging enabled, so Copilot interactions and sharing changes are recorded.

• **Why required:** Copilot-side verification and the before/after evidence rely on the audit trail.

• **How to verify:** Purview portal → **Audit** shows recording is on; `Search-UnifiedAuditLog` returns recent events.

• **How to implement if missing:** Enable auditing (Purview **Audit** → *Start recording user and admin activity*); allow time for backfill before relying on it.

Global Requirements — Copilot (category-level)

These requirements apply to every solution in the Copilot category. They are published once at the category level so individual listings stay small. Confirm these before deploying any Microsoft 365 Copilot solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Copilot inherits the tenant's existing identity, permission, and data-governance posture. It creates no new access — but it surfaces everything a user already has. Treat data readiness (oversharing, labeling) as a prerequisite, not an afterthought, and pilot before broad enablement.*

G1. Microsoft 365 tenant with supported workloads

Description: A Microsoft 365 tenant with Exchange Online, SharePoint Online, OneDrive, and Teams in use. Why: Copilot reasons over Microsoft Graph content across these workloads; they must be provisioned and healthy. Verify: Microsoft 365 admin center shows the services active; users have mailboxes and OneDrive provisioned. Implement: Provision/enable the M365 workloads and confirm users are licensed for them before adding Copilot.

G2. Microsoft 365 Copilot licensing

Description: Microsoft 365 Copilot licenses for the target users (a prerequisite base M365 plan applies). Why: Copilot is a per-user add-on; a user cannot use Copilot without an assigned license on a qualifying base plan. Verify: Admin center -> `Billing -> Licenses`; confirm Copilot licenses and free seats. *Verify current base-plan prerequisites in your tenant.* Implement: Purchase/assign Microsoft 365 Copilot licenses to the pilot cohort; assign via group where possible.

G3. Microsoft Entra ID identity and MFA

Description: Cloud identities in Entra ID with MFA and healthy sign-in. Why: Copilot honors identity and Conditional Access; a weak or broken identity plane undermines both access and security. Verify: Users sign in at `https://entra.microsoft.com` resources; MFA is enforced for the cohort. Implement: Ensure licensed, MFA-protected Entra accounts (see the Entra category solutions for identity hardening).

G4. Data readiness — permissions & oversharing controls

Description: A known state of SharePoint/OneDrive permissions and sharing (no unmanaged broad access). Why: Copilot can surface any content the user has access to; oversharing becomes AI data exposure. Verify: Review sharing reports / SharePoint Advanced Management signals; run the solution's discovery script. *SAM/Restricted Content Discovery availability varies — verify in your tenant.* Implement: Remediate broad-access sites and links before broad Copilot enablement (see the

oversharing-remediation solution).

G5. Information protection baseline (sensitivity labels)

Description: A published sensitivity-label taxonomy (even minimal) in Microsoft Purview. Why: Labels are how you keep sensitive content out of AI processing where required and audit what Copilot uses. Verify: Purview compliance portal -> Information Protection shows published labels. Implement: Publish a baseline label set (see the Purview information-protection solutions) before enforcing AI guardrails.

G6. Administrative roles

Description: Global Administrator (or scoped admin roles: SharePoint Admin, Security/Compliance Admin) for the operator. Why: Enabling Copilot, remediating SharePoint, and configuring Purview DLP/labels require these roles. Verify: Entra -> `Roles and administrators`; confirm the required roles. Implement: Assign least-privilege roles for the task; reserve Global Administrator for tenant-wide changes.

G7. Network and client readiness

Description: Supported Microsoft 365 Apps clients and network access to Microsoft 365/Copilot endpoints. Why: Copilot experiences in Word/Excel/Outlook/Teams require current clients and connectivity. Verify: Clients on a supported channel/build; Microsoft 365 endpoints reachable. *Verify current client requirements.* Implement: Update the M365 Apps channel/build and allow the required endpoints.

G8. Governance & responsible-use policy

Description: An organizational position on acceptable AI use, data handling, and auditability. Why: Copilot generates and surfaces content; the organization must define what is acceptable and keep an audit trail. Verify: A documented AI-use/acceptable-use policy exists; Copilot interactions are auditable (Purview audit). Implement: Adopt an AI-use policy; enable audit/eDiscovery for Copilot. *Governance and acceptable-use determinations are the customer's compliance/legal decision — this guide covers the technical controls only.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

Follow these steps **in order**. Discovery, validation, and reporting are automated with read-only PowerShell (Microsoft Graph / PnP PowerShell); remediation is done in the **SharePoint admin center** (`https://<tenant>-admin.sharepoint.com`) and the **SharePoint Online Management Shell**, and the bundled remediation script defaults to a **safe preview (`-WhatIf`)** — no sharing changes without `-Commit`. Every object you create follows the `<Purpose> – <Scope> – <Stage>` convention and is reused verbatim in Testing, Troubleshooting, and the scripts.

> ***Model:*** *confirm scope → discover the oversharing → agree the remediation with site owners → configure and **pilot** on a ring of sites → validate (including from the Copilot side) → expand under change control, remove interim controls, and record the evidence. Pattern: **Assess** → **Configure** →*

> ***Pilot → Validate → Expand. Portal-path caveat.*** *SharePoint admin and SAM blades evolve, and several controls (SAM, RCD, RSS) are licensing-gated. The paths below are the current map; if a blade or cmdlet differs in your tenant, use the closest documented equivalent and* ***confirm before acting*** *— never assume a path that is not present.*

Objects you will create (naming reference)

Object	Name	Where
Oversharing inventory export	`Oversharing Discovery – Estate – Assess`	`CPLTSHARE-Discovery.ps1`
Site access-reduction list	`Site Access Reduction – Sites – Pilot`	`CPLTSHARE-Remediation.ps1`
Restricted Access Control lock	`Restricted Access Control – Broad Sites – Pilot`	SharePoint admin / SAM
Restricted Content Discovery scope	`Restricted Content Discovery – Sensitive Sites – Pilot`	SharePoint admin / SAM
Interim tenant search fence	`Restricted SharePoint Search – Tenant – Interim`	SPO Management Shell
Owner-led review	`Site Access Review – Broad Sites – Pilot`	SharePoint admin / SAM
Copilot-side verification	`Copilot Permission Verification – Pilot – Validate`	`CPLTSHARE-Validate.ps1` + manual
Before/after evidence	`Oversharing Remediation Report – Tenant – Expand`	`CPLTSHARE-Report.ps1`
Recurring cadence tag	`Oversharing Review – Tenant – Recurring`	scheduled script chain

Step 0 — Confirm scope, licensing, roles, and connections (Assess)

1. On the operator workstation, sign in for read-only work:

• `Connect-MgGraph -Scopes "Sites.Read.All","Directory.Read.All"` (Microsoft Graph).

• `Connect-PnPOnline -Url https://<tenant>-admin.sharepoint.com -Interactive` (PnP).

• For later RSS steps: `Connect-SPOService -Url https://<tenant>-admin.sharepoint.com`.

1. Run `CPLTSHARE-Discovery.ps1 -ScopeOnly` (read-only). It confirms the sign-ins, reports which modules

and which SAM signals are available, and confirms whether **auditing** is on (Requirements 2.2, 2.3, 2.8). Note any capability absent so you scope around it.

1. Confirm the **in-scope estate and pilot ring** (Requirement 2.4) and the **change window**

(Requirement 2.7) before any change.

Pass/fail: Sign-ins succeed, modules/SAM availability reported, pilot ring and change window agreed. **Rollback:** None — read-only.

Step 1 — Discover the oversharing (Assess)

1. Run `CPLTSHARE-Discovery.ps1` (read-only). It enumerates the in-scope SharePoint sites via Graph/PnP

and surfaces the **oversharing signals** — **EEEU / org-wide grants**, **"Anyone" (anonymous) links**, broad company-wide sharing links, large-membership sites, and stale/guest access — writing `Oversharing Discovery – Estate – Assess` (CSV + JSON summary).

1. Where **SAM** is licensed, also open the SharePoint admin center → **Reports** → **Data access governance**

and run the **Sharing links**, **Everyone Except External Users (EEEU)**, and **Sensitivity labels applied to files** reports. The DAG reports are the **authoritative tenant view**; reconcile them with the portable script export.

1. **Rank** the results: broadly-shared sites are the priority, especially those that also hold sensitive

or unlabeled content (cross-read with the Copilot data-governance discovery if available).

Pass/fail: The export lists in-scope sites with their oversharing signal; the top targets can be named. **Rollback:** None — read-only.

Step 2 — Agree the remediation with site owners (Configure)

1. Produce the prioritized reduction list: run

`CPLTSHARE-Remediation.ps1 -Action BuildList -Name "Site Access Reduction – Sites – Pilot"` (read-only). It turns `Oversharing Discovery – Estate – Assess` into a ranked, per-site action list (remove EEEU, revoke anonymous links, scope to a group, review guests) — it changes **nothing**.

1. Walk the list with the **site owners** (Requirement 2.5). For each pilot site, agree: the correct

audience, which broad grants/links to remove, whether to lock the site with **RAC**, and whether it needs interim **RCD** fencing while cleanup proceeds.

1. **Record the decisions.** *Who should have access and what is "too broad" are the owners' data-owner

determinations* — you implement and pilot the agreed changes; you do not decide access.

Pass/fail: The reduction list is produced and the per-site owner decisions are recorded. **Rollback:** None — planning only.

Step 3 — Pilot: reduce access on the ring (Configure → Pilot)

Apply only to the **pilot ring**; nothing tenant-wide is enforced.

1. **Preview first.** Run

`CPLTSHARE-Remediation.ps1 -Action ReduceAccess -Name "Site Access Reduction – Sites – Pilot" -WhatIf` to review exactly which grants/links would be removed. Add `-Commit` only after owner sign-off.

1. **Remove broad grants and links** on each pilot site (under SharePoint Administrator): remove **EEEU**

and org-wide grants; revoke **"Anyone"/anonymous** and over-broad **company** sharing links; remove stale guests/members. Do this via the script (`-Commit`) or the site's **Site permissions** and **Manage access** UI.

1. **Lock high-risk sites with RAC (where SAM is licensed).** In the SharePoint admin center → **Active

sites → **select the site** → Settings → Restricted access control**, limit the site to a named security group. Name the configuration `Restricted Access Control – Broad Sites – Pilot`.

1. **Interim containment while you clean up.** For not-yet-remediated sensitive sites that must be fenced

from Copilot immediately:

• **RCD (per site, SAM):** SharePoint admin center → **Active sites** → site → enable **Restricted

Content Discovery** (excludes the site's content from Copilot and org-wide search). Name it `Restricted Content Discovery – Sensitive Sites – Pilot`.

• **RSS (tenant, interim):** in the SPO Management Shell,

`Set-SPOTenantRestrictedSearchMode -Mode Enabled`, then `Add-SPOTenantRestrictedSearchAllowedListUrls -Urls "<allowed site URLs>"` to allow only cleaned sites. Record as `Restricted SharePoint Search – Tenant – Interim`. Treat RSS/RCD as **temporary stopgaps**, not the end state. *(SAM/RSS/RCD availability is tenant-dependent — verify.)*

1. **Kick off owner-led site access reviews (where SAM is licensed).** In the SharePoint admin center,

start **site access reviews** for the broad sites so owners confirm/clean membership. Name the batch `Site Access Review – Broad Sites – Pilot`.

Pass/fail: Pilot-site broad grants/links removed (or previewed and owner-approved), RAC/RCD applied where agreed, interim RSS recorded, access reviews started. **Rollback:** Restore prior sharing on any site where a change broke legitimate access (the discovery export is the before-state); disable RCD on a site; `Set-SPOTenantRestrictedSearchMode -Mode Disabled` to turn RSS off.

Step 4 — Align sensitivity labels & DLP (Configure)

1. Confirm the **sensitivity-label** baseline (Requirement 2.6). Where high-risk pilot sites hold

sensitive content, ensure the appropriate label (with **encryption/usage rights** where warranted) is applied — Copilot honors item-level encryption and will not surface content the user cannot decrypt.

1. Confirm any **DLP-for-Copilot** policy (built in the Copilot data-governance solution) covers the

"keep out of Copilot" labels for this content. This solution **aligns** with that layer; it does not build it. Note label/DLP alignment as pending if that layer is not yet in place.

Pass/fail: Labels applied/aligned on high-risk pilot content; DLP-for-Copilot coverage confirmed or noted pending. **Rollback:** Adjust label scope; no access change here.

Step 5 — Validate the pilot, including from the Copilot side (Validate)

1. Run `CPLTSHARE-Validate.ps1` (read-only). It re-reads the oversharing signal for the pilot sites and

confirms it is **lower** than the Step 1 baseline, that RAC/RCD/RSS are in the expected state, and that auditing is on. It writes `Copilot Permission Verification – Pilot – Validate`.

1. **Copilot-side check (manual, decisive).** As a **test user who should *not* have access** to a

remediated site, open Microsoft 365 Copilot and prompt for content that used to be reachable (e.g. *"Summarize the <site> budget file"* or search for a known phrase). Copilot must **not** return that content. As a **legitimate user**, confirm expected content is **still** reachable (no collaboration broken). Record both outcomes against `Copilot Permission Verification – Pilot – Validate`. *(Copilot indexes on a cadence; allow time after a permission change before the negative test is reliable — see Troubleshooting.)*

1. Confirm with owners that nothing legitimate broke. See Testing (doc 5) for explicit gates.

Pass/fail: Oversharing reduced on re-measure; the test user can no longer surface remediated content; legitimate access intact. **Rollback:** If a legitimate access broke, restore it and re-scope; do not expand until the gate passes.

Step 6 — Expand, remove interim controls, and record the evidence (Expand)

1. Only after the pilot gate passes: repeat Steps 3–5 for the **remaining waves** under change control,

widening RAC and access reviews beyond the pilot ring.

1. **Remove interim controls once the underlying access is fixed:** disable **RSS**

(`Set-SPOTenantRestrictedSearchMode -Mode Disabled`) and remove **RCD** on sites whose access is now correct — the goal is fixed access, not a permanent search fence.

1. Run `CPLTSHARE-Report.ps1` (read-only) to compile `Oversharing Remediation Report – Tenant – Expand` —

the **before/after oversharing**, the controls applied and their state, and the residual risk — for stakeholder sign-off.

1. Stand up the recurring review: tag the cadence `Oversharing Review – Tenant – Recurring` and schedule

the read-only `Discovery → Validate → Report` chain (e.g. monthly) so oversharing stays measured as sites, sharing, and Copilot usage change.

Pass/fail: Remediation expanded, interim controls removed, before/after report compiled and signed off, recurring review scheduled. **Rollback:** Restore prior sharing on any site where broad enforcement caused an issue; re-apply RSS/RCD containment if a wave must pause. The discovery and report exports are the before-state to restore toward.

5. Testing & Validation — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

Validate the build against explicit **pass/fail gates** before expanding beyond the pilot ring. Discovery, validation, and reporting are automated; the decisive Copilot-side check is a short manual test. Run the scripts read-only (they change nothing) and record each result against the named object.

> ***Principle:*** *the pilot gate is *both* a measured reduction in the oversharing signal **and** a Copilot-side confirmation that a user who should not have access can no longer surface the content — with no legitimate collaboration broken. Do not enforce broadly until every gate below passes.*

Test 1 — Scope & connections (Step 0)

- **Procedure:** Run `CPLTSHARE-Discovery.ps1 -ScopeOnly`.
- **Pass:** Graph/PnP sign-ins succeed; module and SAM availability are reported; auditing is on; pilot ring and change window are agreed.
- **Fail:** A sign-in fails or auditing is off → resolve (Requirements 2.1–2.3, 2.8) before proceeding.

Test 2 — Oversharing discovery produced (Step 1)

- **Procedure:** Run `CPLTSHARE-Discovery.ps1`; open `Oversharing Discovery – Estate – Assess`.
- **Pass:** The export lists in-scope sites with an oversharing signal (EEEU / anonymous links / broad links / large membership / stale access); the top targets can be named; where SAM is licensed, the numbers reconcile with the **Data Access Governance** reports.
- **Fail:** Empty or partial export → confirm read scope (`Sites.Read.All`) and site enumeration; fall back to the SharePoint admin **Active sites** export as the site list.

Test 3 — Reduction list & owner decisions (Step 2)

- **Procedure:** Run `CPLTSHARE-Remediation.ps1 -Action BuildList -Name "Site Access Reduction – Sites – Pilot"`.
- **Pass:** A ranked per-site action list is produced; owner decisions (audience, grants/links to remove, RAC/RCD) are recorded for each pilot site.
- **Fail:** No owner for a site → escalate to name one before remediating (Requirement 2.5).

Test 4 — Remediation preview is safe (Step 3)

- **Procedure:** Run `CPLTSHARE-Remediation.ps1 -Action ReduceAccess -Name "Site Access Reduction – Sites – Pilot" -WhatIf`.
- **Pass:** The preview lists exactly which grants/links **would** be removed and changes nothing; the set matches the owner-approved decisions.

• **Fail:** The preview would touch a site/grant not approved → correct the list before any `-Commit`.

Test 5 — Pilot access reduced (Step 3)

• **Procedure:** After `-Commit` (and manual RAC/RCD/RSS as agreed), re-run `CPLTSHARE-Discovery.ps1`

scoped to the pilot sites.

• **Pass:** EEEU/org-wide grants and anonymous/broad links are gone on the pilot sites; RAC limits the agreed sites to a named group; RCD/RSS are in the recorded state.

• **Fail:** A broad grant/link remains → re-check the site's **Manage access** and re-run remediation.

Test 6 — Copilot honors the corrected permissions (Step 5) — decisive

• **Procedure:** Run `CPLTSHARE-Validate.ps1`, then perform the manual `Copilot Permission Verification –

Pilot – Validate` check:

1. As a **test user who should NOT have access** to a remediated site, prompt Copilot for content that was previously reachable, and search for a known phrase from that content.

1. As a **legitimate user**, confirm the content they *should* see is still reachable.

• **Pass:** The unauthorized user gets **no** access to the remediated content via Copilot or search; the legitimate user's access is intact; `CPLTSHARE-Validate.ps1` shows the oversharing signal lower than the baseline and RAC/RCD/RSS in the expected state.

• **Fail:** The unauthorized user can still surface the content → confirm the grant/link was actually removed, allow for Copilot re-indexing latency (Troubleshooting), and consider interim RCD/RSS fencing; do not expand until this passes.

Test 7 — No legitimate collaboration broke (Step 5)

• **Procedure:** With site owners, spot-check that pilot-site members can still open, edit, and share as intended.

• **Pass:** Owners confirm expected access is intact; no broken links or lost membership for legitimate users.

• **Fail:** A legitimate access broke → restore it from the discovery before-state and re-scope the reduction.

Test 8 — Before/after evidence & recurring review (Step 6)

• **Procedure:** Run `CPLTSHARE-Report.ps1`; open `Oversharing Remediation Report – Tenant – Expand`;

confirm the recurring `Oversharing Review – Tenant – Recurring` chain is scheduled.

• **Pass:** The report shows the before/after oversharing, controls applied and their state, and residual risk; interim RSS/RCD removed where access is fixed; the read-only review chain is scheduled.

• **Fail:** Report incomplete or interim controls still in place without justification → complete remediation and re-run.

Evidence to retain

• `Oversharing Discovery – Estate – Assess` (baseline) and the post-remediation re-measure.

• `Copilot Permission Verification – Pilot – Validate` (both the script output and the manual test outcomes).

• `Oversharing Remediation Report – Tenant – Expand` (the before/after sign-off record).

• The recorded owner decisions from Step 2 (the data-owner determinations behind each change).

6. Troubleshooting — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

Common failures, their cause, and the fix. Symptoms map to the implementation steps.

Discovery returns no sites / partial results

• **Symptom:** `CPLTSHARE-Discovery.ps1` writes an empty or short `Oversharing Discovery – Estate – Assess`.

• **Cause:** Missing read scope, wrong sign-in, or site enumeration returning nothing for the account.

• **Fix:** Reconnect with `Connect-MgGraph -Scopes "Sites.Read.All","Directory.Read.All"` and/or `Connect-PnPOnline`. Confirm the account can read the sites. Fall back to the SharePoint admin center **Active sites** export as the site list and re-run.

Permission read is unavailable for a site

• **Symptom:** Sites appear with a "permission read unavailable / needs higher scope" note.

• **Cause:** The discovery identity lacks rights to read that site's permissions.

• **Fix:** This is expected in read-only discovery. Use the SharePoint admin **Data Access Governance** reports (SAM) as the authoritative view, or elevate the discovery identity's read rights for the in-scope sites.

Data Access Governance / RAC / RCD blades are missing

• **Symptom:** No **Reports** → **Data access governance**, **Restricted access control**, or **Restricted

Content Discovery** in the SharePoint admin center.

- **Cause: SharePoint Advanced Management (SAM)** is not licensed/enabled, or the feature has moved.

(SAM is a paid add-on and its surface evolves — verify.)

- **Fix:** Acquire/enable SAM, or proceed with **manual sharing cleanup** plus interim **RSS** and note

the SAM controls as pending. The scripts degrade gracefully when SAM is absent.

Removed the grant, but Copilot still surfaces the content

- **Symptom:** After remediation, the test user can still get the content via Copilot or search.
- **Cause 1 — indexing latency:** Copilot/search re-indexes on a cadence; the change has not propagated

yet. **Fix:** Wait the re-index window and re-test; record the test time.

- **Cause 2 — access still exists via another path:** A different broad link, a group membership, or a

parent-site grant still applies. **Fix:** Re-run `CPLTSHARE-Discovery.ps1` on that site, check **Manage access** for every path, and remove the remaining grant/link.

- **Cause 3 — content cached in a prior response/history: Fix:** Confirm against a fresh prompt; prior

chat history is not new access. Apply interim **RCD/RSS** if immediate fencing is required.

Restricted SharePoint Search broke legitimate search/Copilot

- **Symptom:** After enabling RSS, users can't find sites they should.
- **Cause:** RSS blocks everything **not** on the allow-list (max 100 sites); a needed site was omitted.
- **Fix:** Add the site with `Add-SPOTenantRestrictedSearchAllowedListUrls -Urls "<url>"`, or disable RSS

with `Set-SPOTenantRestrictedSearchMode -Mode Disabled`. Remember RSS is an **interim** stopgap — remove it once real access is fixed.

Remediation broke legitimate collaboration

- **Symptom:** After `-Commit`, legitimate users lost access to a pilot site.
- **Cause:** A grant that was actually needed was removed (audience mis-scoped with the owner).
- **Fix:** Restore from the before-state (`Oversharing Discovery – Estate – Assess` and the site's version

history / re-grant), re-scope with the owner, and re-run the `-WhatIf` preview before re-committing.

`-WhatIf` shows a change you didn't approve

- **Symptom:** The remediation preview would touch a site or grant not on the approved list.
- **Cause:** The reduction list included a site/grant beyond the owner-approved set.

- **Fix:** Correct `Site Access Reduction – Sites – Pilot` to match the recorded owner decisions; never

`-Commit` a change that wasn't approved.

SPO Management Shell RSS cmdlets not recognized

- **Symptom:** `Set-SPOTenantRestrictedSearchMode` / `Add-SPOTenantRestrictedSearchAllowedListUrls` error

as not found.

- **Cause:** Old `Microsoft.Online.SharePoint.PowerShell` module, or the tenant lacks the feature.
- **Fix:** `Update-Module Microsoft.Online.SharePoint.PowerShell`; reconnect with `Connect-SPOService`.

If still absent, RSS may not be available in your tenant *(verify)* — use per-site RCD instead.

Validation shows oversharing unchanged after remediation

- **Symptom:** `CPLTSHARE-Validate.ps1` reports the pilot signal at or near baseline.
- **Cause:** The `-Commit` step wasn't run, targeted the wrong sites, or the discovery cache is stale.
- **Fix:** Confirm remediation actually committed to the pilot sites; re-run discovery/validation; verify

the pilot-site scope matches between the remediation and validation runs.

Auditing / verification data missing

- **Symptom:** No Copilot interaction or sharing-change events for the verification record.
- **Cause:** Unified audit logging was off or recently enabled (backfill delay).
- **Fix:** Enable auditing (Purview **Audit**), allow time for events to populate, then re-run the

verification and `CPLTSHARE-Report.ps1`.

7. Best Practices — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

Keep the corrected boundary clean over time, and know where to go next in the catalog.

Keep it clean

- **Fix access, don't just fence it.** RSS and RCD are **interim stopgaps** to buy time — the durable win

is removing the broad grant and scoping the site. Remove interim controls once the underlying access is correct; a permanent search fence hides the problem instead of solving it.

- **Pilot before you enforce, always.** Preview every reduction with `-WhatIf`, remediate a ring first,

validate (including the Copilot-side test), then expand. Never remove broad access tenant-wide in one step.

- **Let owners own access.** *Who should have access* is a data-owner decision. Drive cleanup through **site access reviews** so owners confirm membership; you supply the discovery and the remediation method, not the access verdict.
- **Default to least privilege at creation.** Prevent new oversharing: disable/limit **"Anyone" links** tenant-wide, set the default sharing link to **specific people** or **people in your org**, and use **site creation policies** so new sites start scoped, not broad.
- **Watch EEEU specifically.** "Everyone Except External Users" is the single most common Copilot oversharing source. Track it in the **Data Access Governance** EEEU report and keep it near zero on content-bearing sites.
- **Reinforce with information protection.** Sensitivity labels with **encryption/usage rights** are honored by Copilot at item level — defense in depth beyond sharing settings. Keep the label + DLP layer aligned (see the Copilot data-governance solution).
- **Re-measure on a cadence.** Sharing drifts as people collaborate. Run the read-only `Discovery → Validate → Report chain monthly (Oversharing Review – Tenant – Recurring`) and treat any new EEEU / anonymous link on a content site as a finding.
- **Mind Copilot indexing latency.** A permission change is not instantly reflected in Copilot results; allow the re-index window before trusting a negative test, and record the test time.
- **Keep the evidence.** Retain the before/after exports and the Copilot-side verification — they are your defensible record that oversharing was closed before broad Copilot rollout.
- **Least-privilege the operator.** Use SharePoint Administrator for remediation and read scopes for discovery; reserve Global Administrator for tenant-wide changes.

Where to go next (adjacent catalog areas)

- **Copilot — Data Governance & DLP Guardrails:** the information-protection counterpart to this solution — sensitivity labels on Copilot-accessible content, **DLP for Microsoft 365 Copilot**, prompt/response guardrails, and audit/eDiscovery of Copilot interactions. Build it alongside this one.
- **Purview — Information Protection & Sensitivity Labels:** design and publish the label taxonomy, auto-labeling, and container labeling that reinforce corrected access.
- **Purview — Data Loss Prevention:** the broader DLP program (endpoint, cloud, email) that the Copilot-scoped DLP sits within.
- **Purview — Copilot Data-Protection Readiness / DSPM for AI:** the Purview-centric readiness and exposure-insight view that complements this SharePoint-permissions remediation.
- **Entra — Identity & Conditional Access:** harden the identity plane Copilot honors (MFA, CA, PIM) so

access decisions are enforced end to end.

• **SharePoint / M365 governance:** site lifecycle, external sharing policy, and guest governance to stop oversharing recurring at the source.

8. Deliverables Summary — Secure Microsoft 365 Copilot: Oversharing & SharePoint Permissions Remediation

Everything included in this solution, and how it is delivered.

Documentation (8 guides)

#	Document	Purpose
—	`executive-summary.md`	What it is, the outcome, the boundary, and the effort.
1	`01-solution-overview.md`	What it is, how Copilot honors SharePoint permissions, and the Assess → Configure → Pilot → Validate → Expand model; scope and connections.
2	`02-requirements.md`	Solution-specific prerequisites (roles, PowerShell modules, SAM, pilot ring, owners, change window, auditing). Category prerequisites live in the global-requirements file.
3	`03-implementation.md`	Exact, ordered steps to discover, remediate, and verify oversharing — every object named and reused.
5	`05-testing.md`	Pass/fail validation gates, including the decisive Copilot-side permission test.
6	`06-troubleshooting.md`	Symptom → cause → fix for the common failures.
7	`07-best-practices.md`	Keep-it-clean guidance and where to go next in the catalog.
8	`08-deliverables-summary.md`	This inventory.

> *Category-level prerequisites are published once in* `global-requirements-copilot.md` *and are not repeated in the per-solution docs.*

PowerShell scripts (5)

All scripts are white-label, store no secrets, and are **read-only by default**; the one script that can change sharing defaults to a **safe preview (`-WhatIf`)** and requires an explicit `-Commit`.

Script	Purpose
`CPLTSHARE-Discovery.ps1`	**Read-only.** Confirms connections/modules/SAM/audit (`-ScopeOnly`), then enumerates in-scope SharePoint/OneDrive sites and surfaces oversharing signals (EEEU, anonymous links, broad links, large membership, stale access). Writes `Oversharing Discovery – Estate – Assess`.
`CPLTSHARE-AccessReview.ps1`	**Read-only.** Produces a per-site **access-review workbook** (owners, members, guests, broad grants, sharing links) to drive owner-led cleanup.
`CPLTSHARE-Remediation.ps1`	**Safe preview / `-WhatIf` by default; `-Commit` gated.** Builds the ranked `Site Access Reduction – Sites – Pilot` list (read-only), and — only with `-Commit` — removes EEEU/org-wide grants and anonymous/broad links on approved pilot sites. RAC/RCD/RSS steps are documented for the portal / SPO shell.
`CPLTSHARE-Validate.ps1`	**Read-only.** Re-measures the pilot oversharing signal against baseline, confirms RAC/RCD/RSS state and auditing, and records `Copilot Permission Verification – Pilot – Validate` (pairs with the manual Copilot-side test).
`CPLTSHARE-Report.ps1`	**Read-only.** Compiles the before/after `Oversharing Remediation Report – Tenant – Expand` — controls applied, their state, and residual risk — for stakeholder sign-off.

How it is delivered

Delivered as a **Complete Solution Package (PDF + Word + scripts)** in a single ZIP (`CPLTSHARE-Complete-Solution.zip`) — the eight guides as a formatted Word document and PDF, plus the five PowerShell scripts, yours to keep and reuse on every remediation wave.

Boundaries recap

- **Data-owner access determinations** (who should have access, what is "too broad") remain with site owners and the business — this package provides discovery, remediation method, and evidence.
- **SAM / Restricted Content Discovery / Restricted SharePoint Search** are licensing-/tenant-dependent and evolving — availability is flagged "verify," never assumed.

• The **sensitivity-label taxonomy and DLP-for-Copilot policies** are built in the Copilot data-governance

solution / Purview information-protection solutions and are referenced, not rebuilt, here.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CPLTSHARE-AccessReview.ps1

CPLTSHARE-Discovery.ps1

CPLTSHARE-Remediation.ps1

CPLTSHARE-Report.ps1

CPLTSHARE-Validate.ps1